

Mutillidae II Group Security Project Report

Four vulnerability fixes with local evidence and separate member pull request packages

IE3142 Continuous Assessment | 30 September 2026

Prepared for the module assessment. The selected route fixes passed local validation. Inherited dependency and image findings remain open; genuine GitHub evidence and signed submission documents must be completed by the group.

Member	Student ID	Assigned responsibility
Oshadha	IT24103920	SQL injection, Docker and architecture
Pathum	IT24102334	Stored XSS and STRIDE threat model
Minura	IT24104168	Command injection and security pipeline
Muditha	IT24610813	CSRF, secrets and report integration

Repository: <https://github.com/oshadha-001/Devsec-group-project>

Group number: _____

Source: Mutillidae tag 2.12.7, commit 3df16679355f393f0488ad5ca1b7020141f52580. The application itself displays version 2.12.6.

Submission rule: one submission for the group through Courseweb, including the actual signed Ethical Clearance Form. The supplied guidance states a 1 October 2026 deadline; the group must confirm the published time.

AI disclosure: Codex prepared the implementation, test automation, local evidence and report draft. Students must record their own review, corrections and validation before signing the contribution statement.

Contents

1 Executive summary	3
2 System architecture and reproducibility	4
3 Threat model and priorities	5
4 Vulnerability analysis and remediation	6
5 Security pipeline and measured results.....	8
6 Secrets management	9
7 Industry practice and case study	9
8 Reflection and submission readiness.....	9
References	10
Appendix A Actual exploit and retest screenshots	11
Appendix B Verification and open findings.....	19
Appendix C Individual contributions and declarations.....	20
Appendix D Sequential GitHub and submission workflow	21

Main narrative: approximately 2,200 words including the threat matrix, excluding cover, references and appendices. All screenshots are actual local browser captures. Captions distinguish observed results from remaining submission work.

1 Executive summary

This project demonstrates four source-level security improvements to OWASP Mutillidae II for the IE3142 group assessment. The selected application is an intentionally vulnerable teaching system. The implementation addresses SQL injection in account lookup, stored cross-site scripting in blog display, operating-system command injection in DNS lookup, and cross-site request forgery in blog submission. These changes run in a two-component PHP and MySQL deployment. The remaining teaching exercises are outside the remediation scope and retain known weaknesses.

Local validation reproduced all four selected attacks against the vulnerable handlers and replayed identical inputs against the corrected application. SQL injection returned 40 accounts before correction and zero afterward. Stored script content stopped executing, injected command output disappeared, and a tokenless blog request changed from a successful insertion to HTTP 403 with no inserted entry. Legitimate account lookup, blog submission and hostname lookup continued working. All 15 recorded browser checks and the three focused PHP test suites passed.

The delivery contains a common foundation and four sequential member packages. The assigned owners are Oshadha, Pathum, Minura and Muditha. Code preparation, local testing and report drafting were assisted by Codex; these activities do not establish completed student contributions. Each member must independently review and understand their patch, record their actual work and submit their own pull request. Hosted GitHub evidence and signed documents remain group responsibilities. Wider dependency and image findings are reported openly rather than treated as resolved by the four fixes.

2 System architecture and reproducibility

The source is pinned to upstream release tag 2.12.7, commit 3df16679355f393f0488ad5ca1b7020141f52580 [1]. Its application banner and version file identify 2.12.6; both identifiers are retained to make the screenshots traceable. The GPL licence and upstream component notices accompany the source. The comparison deployment preserves the four vulnerable handlers, but shares documented configuration and seed adaptations. It is therefore an adapted baseline, not a byte-for-byte untouched upstream deployment.

Apache and PHP 8.2 serve the application, while MySQL 8.4 stores synthetic users and blog entries. A short-lived seed service initializes the original schema and synthetic records. Health checks ensure the database becomes available before initialization and the web service starts afterward. Persistent database storage survives ordinary restarts. The final browser endpoint is restricted to 127.0.0.1:8080; the separate baseline uses port 8081 and its own volume. MySQL exposes no host port and communicates over an internal Docker network.

Browser requests cross a trust boundary into PHP, and database operations cross another boundary into MySQL. Runtime secret files enter only the services that need them. Container isolation reduces accidental exposure but does not remove application vulnerabilities. The browser test runner denied requests to non-loopback hosts, demonstrating the selected local exercises without third-party browser services. A complete network-disconnected host test was not performed. Images, scanner databases and build dependencies require initial downloads or prepared caches before an offline demonstration.

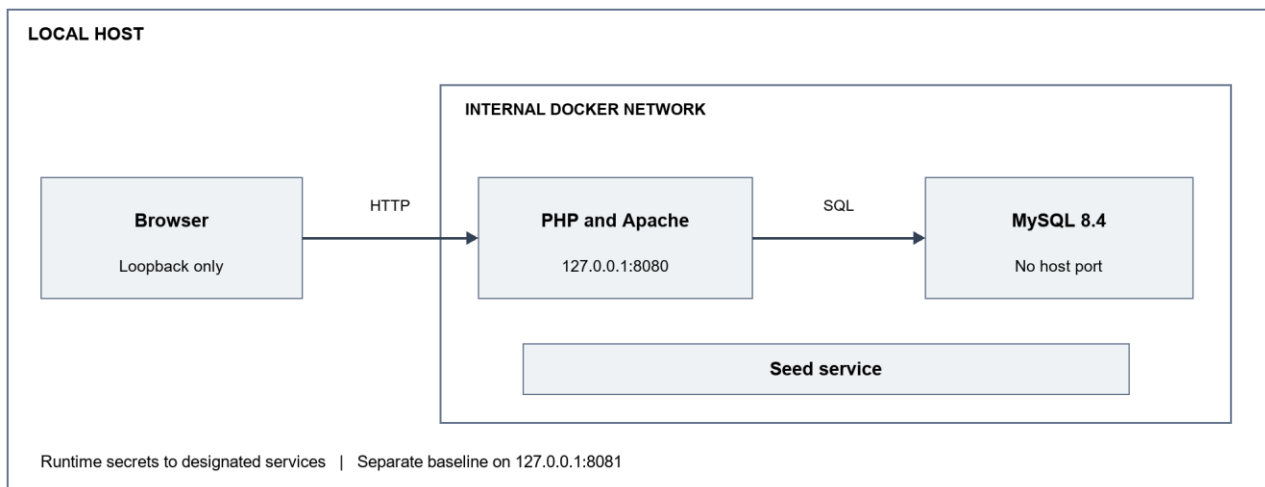


Figure 1 Runtime components and trust boundaries. The seed service exits after initialization. GitHub Actions operates in a separate CI environment.

3 Threat model and priorities

The assessment uses STRIDE categories and a qualitative likelihood-times-impact score. Both factors range from one to three; the score prioritizes this teaching deployment rather than estimating real incident probability. Account lookup receives a high likelihood because a signed-in user directly supplies the query input. Persisted blog content reaches later readers, making stored script execution similarly accessible. DNS input originally crossed directly into a shell. CSRF likelihood is lower because exploitation depends on an authenticated browser and its cookie policy.

The threat matrix maps six concrete threats to implemented or proposed controls. Each selected route is tested at security level zero so the protections cannot be bypassed merely by switching the demonstration setting. Residual risks remain material: other SQL queries, output paths and state-changing operations are intentionally vulnerable; synthetic passwords remain plaintext in the application database; and bundled libraries have incomplete version identification. Stronger authorization, password hashing, restricted database privileges and comprehensive auditing are subsequent work, not claims of this submission.

Threat and STRIDE category	L × I	Control and residual issue
Account SQL injection — tampering and disclosure	$3 \times 3 = 9$	Prepared statement in getUserAccount; other queries remain.
Stored blog script — tampering and elevation	$3 \times 3 = 9$	HTML encoding in the blog viewer; other contexts need review.
DNS command execution — elevation and tampering	$3 \times 3 = 9$	GroupDns removes the shell; restricted lookup behavior.
Forged blog post — spoofing and tampering	$2 \times 2 = 4$	Authenticated session and GroupCsrf; other routes remain.
Credential disclosure — information disclosure	$2 \times 3 = 6$	Runtime secrets and Gitleaks; database passwords remain plaintext.
Inherited dependencies — tampering and elevation	$2 \times 3 = 6$	Inventory and Trivy gates; detected findings remain open.

4 Vulnerability analysis and remediation

4 1 Oshadha IT24103920 SQL injection

The account lookup built a SQL string containing user-controlled credentials. An authenticated synthetic user submitted username jeremy and the password payload shown in Appendix A. The quote and Boolean expression changed the WHERE condition, causing 40 account records to be returned. Credentials visible in that response were masked before the screenshot was saved. This demonstrates information disclosure through a query boundary failure, classified as CWE-89.

The corrected SQLQueryHandler::getUserAccount method uses two placeholders and passes the values separately to a mysqli prepared statement through MySQLHandler::executePrepared. It also rejects non-string or oversized inputs. This follows the separation of query structure and data described by OWASP [2]. The identical malicious password then returned zero records, while the real synthetic user's credentials still returned one record. A query-recorder unit test verifies binding and malformed-input handling; the browser test supplies the complementary live-database evidence. The fix is confined to this method and does not certify every query in Mutillidae.

4 2 Pathum IT24102334 Stored cross site scripting

The blog viewer rendered stored author and comment fields into HTML. A harmless script inserted a visible GROUP-XSS-PROOF heading into the page, proving browser execution after storage and retrieval. It neither collected cookies nor contacted an external server. The failure is CWE-79: application data was interpreted as active markup in another user's browser context.

The patch applies htmlspecialchars with ENT_QUOTES, ENT_SUBSTITUTE and UTF-8 to the blog author, date, comment and author-selection output. The protection applies independently of the demonstration security level. A small set of trusted formatting tokens remains explicitly controlled by the page. Retesting the same stored script produced visible literal script text and no injected heading. Ordinary blog content remained readable. This result supports HTML-context encoding at the selected output locations; JavaScript, URL or CSS contexts elsewhere would require their own context-appropriate controls and separate tests.

4 3 Minura IT24104168 Command injection

The original DNS lookup passed a submitted hostname into an operating-system command. The input 127.0.0.1; printf GROUP-CMD-PROOF caused the marker to appear inside command output. The proof checks that output region, because reflection of the input in the page heading alone would not demonstrate command execution. This is CWE-78 and could allow operations with the web process's privileges.

The replacement GroupDns helper validates a bounded hostname or literal IP address and performs address resolution through PHP. It never constructs or invokes a shell command. Invalid input receives a generic error and HTTP 400 rather than a diagnostic stack trace. The same command payload produced no execution marker after correction, and a localhost lookup succeeded. Focused tests cover IPv4, IPv6, localhost, shell metacharacters, oversized input and non-string values. The DNS exercise now provides address resolution rather than every feature of the original command-line utility; this is an intentional functional tradeoff that removes the dangerous boundary.

4 4 Muditha IT24610813 Cross site request forgery

At security level zero the original blog token handler accepted submissions without validating a token. The test logged in as jeremy and submitted a form from 127.0.0.1:8090 to the application. The baseline inserted a uniquely marked blog entry and returned HTTP 200. Both endpoints are the same site but different origins, with SameSite=Lax cookies. This proves the recorded browser condition; it does not assert that every unrelated external site can send the session cookie.

GroupCsrf generates a random 32-byte session token and validates the submitted POST value using hash_equals. Authentication and token validation occur before insertion, independently of the lab setting [3]. Missing, malformed and cross-session tokens fail. Output buffering permits the included handler to send an actual HTTP 403 response after template processing begins. The identical tokenless form then returned 403 and the unique entry was absent from the stored blog list. A valid form submission still persisted. Token lifecycle tests also verify stability within a session and rejection after switching sessions. Other state-changing routes remain outside this patch.

5 Security pipeline and measured results

The prepared GitHub workflow separates PHP validation, SAST, software composition analysis, secret scanning and image scanning. A final job succeeds only when all required jobs succeed. Reports are uploaded even when a security job fails. The targeted Semgrep rules inspect the four selected anti-patterns; they are deliberately bounded and cannot establish whole-application security. Using Semgrep 1.112.0 and the same rules, the baseline produced four findings and the final source produced zero, with no scanner errors. Enforcing the error option returned exit code one before correction and zero afterward [4].

Gitleaks 8.24.2 found no leaks in the final source-directory scan after static signing keys and token examples were removed or replaced. The hosted workflow requests full Git history, which must be checked after real commits exist. A directory result cannot substitute for history analysis. Source examples, generated credentials and screenshot content must also be reviewed before publication.

The application vendors old libraries without a Composer lockfile. A generated CycloneDX inventory records observed version banners and file hashes: two jQuery copies, Colorbox and NuSOAP. Only the two jQuery entries have verified package identities for the dependency scan. JWT, Gritter and menu code remain unresolved inventory coverage. The SCA gate scans the identified packages and rejects high or critical findings; an incomplete inventory is not an empty vulnerability list. Trivy 0.60.0 also scans both application and database images [5]. Appendix B reports the actual measured counts and outcomes, including failed gates.

The local Semgrep comparison demonstrates a working blocking command. It is not a hosted pipeline screenshot. A separate manual GitHub demonstration temporarily adds a detectable shell sink to the runner workspace so the SAST job fails; it does not commit or publish that source. The group must run it, retain the run URL and capture genuine Actions evidence. Stage three can remain red while the later CSRF patch is pending. Existing dependency and image findings also prevent a truthful claim that every gate is green.

6 Secrets management

The initializer generates cryptographically random local credentials in ignored .secrets files. Compose mounts the application database password and signing key into the web service; root and seed-user credentials have narrower service assignments. Web database reset and credential export files are disabled. These changes remove live defaults from tracked source, but do not introduce password hashing into the original application schema.

The manual runtime workflow requires an encrypted Actions secret named LAB_DB_PASSWORD, containing 64 lowercase hexadecimal characters. The initializer consumes it without printing its value, and generates other credentials on the runner. Fork pull requests receive no such secret. GitHub distinguishes stored secret configuration from values passed to a job [6]. Replacing a local file does not rotate a password already stored in MySQL; rotation needs a deliberate account update. Screenshots must reveal secret names only, never values or session cookies.

7 Industry practice and case study

NIST's Secure Software Development Framework 1.1 describes integrating security practices into a development lifecycle [7]. Here that principle is expressed through small reviewable changes, automated checks, retained evidence and explicit residual-risk tracking. The four packages make it possible to connect one finding to a control, test and reviewer, provided students record genuine contributions.

The December 2021 Log4j response illustrates why source fixes alone are insufficient. CISA and international partners issued coordinated mitigation guidance for vulnerabilities in a widely reused logging component [8]. This project does not claim to use Log4j. The relevant lesson is dependency visibility: copied libraries can be hard to identify and missed by a package-manager-only scan. Recording version banners, hashes and inventory gaps makes that limitation visible. Ongoing component updates and repeated scans are still necessary because new advisories can affect previously accepted versions.

8 Reflection and submission readiness

The strongest outcome is reproducible evidence for the four selected route fixes. The investigation also exposed practical issues: a rejected mutation initially returned the wrong HTTP status, repeated demonstration data cluttered screenshots, and generic dependency discovery did not adequately identify vendored code. Checking persisted state, exact response status and source version banners improved the result beyond a screenshot-only demonstration.

The next priorities are validating unknown libraries, upgrading inherited components, extending controls to related routes and verifying startup on a clean offline demonstration machine. Students must complete their real GitHub reviews and Actions runs, reconcile contribution claims, and sign the statements. One group submission must list all members and roles and include the actual signed ethical-clearance form. The user confirmed clearance was submitted for local testing; the signed file was not available for this package. It must be attached before Courseweb submission. No signature, PR URL or hosted run has been invented.

References

[1] OWASP Mutillidae II source, pinned commit 3df16679355f393f0488ad5ca1b7020141f52580. Accessed 30 September 2026.

<https://github.com/webpwnized/mutillidae/tree/3df16679355f393f0488ad5ca1b7020141f52580>

[2] OWASP, SQL Injection Prevention Cheat Sheet. Accessed 30 September 2026.

https://cheatsheetseries.owasp.org/cheatsheets/SQL_Injection_Prevention_Cheat_Sheet.html

[3] OWASP, Cross Site Request Forgery Prevention Cheat Sheet. Accessed 30 September 2026.

https://cheatsheetseries.owasp.org/cheatsheets/Cross-Site_Request_Forgery_Prevention_Cheat_Sheet.html

[4] Semgrep, CLI reference, including the scan error exit option. Accessed 30 September 2026.

<https://docs.semgrep.dev/cli-reference>

[5] Aqua Security, Trivy v0.60.0 release and tool documentation. Accessed 30 September 2026.

<https://github.com/aquasecurity/trivy/releases/tag/v0.60.0>

[6] GitHub, Using secrets in GitHub Actions. Accessed 30 September 2026.

<https://docs.github.com/en/actions/how-tos/write-workflows/choose-what-workflows-do/use-secrets>

[7] NIST, Secure Software Development Framework Version 1.1, SP 800-218, February 2022. Accessed 30 September 2026.

<https://csrc.nist.gov/pubs/sp/800/218/final>

[8] CISA and partners, Advisory to mitigate Apache Log4j vulnerabilities, 22 December 2021. Accessed 30 September 2026.

<https://www.cisa.gov/news-events/news/cisa-fbi-nsa-and-international-partners-issue-advisory-mitigate-apache-log4j-vulnerabilities>

Assignment sources: IE3142 Continous Assessment PDF and the supplied Submission Guidelines image. The separate EAP Complete Study Guide concerns English study and is not the source of these technical assessment requirements.

Appendix A Actual exploit and retest screenshots

SQL injection before the fix

Assigned owner: Oshadha IT24103920

Authenticated jeremy account lookup. Password input: ' OR 1=1 -- (a space follows the final dashes).

OWASP Mutillidae II: Keep Calm and Pwn On
 Version: 2.12.6 Security Level: 0 (Hosed) Hints: Enabled Logged In User: jeremy
 Home | Logout | Toggle Hints | Toggle Security | Enforce TLS | Reset DB | View Log | View Captured Data

User Lookup (SQL)

[Back](#) [Help Me!](#)

[Hints and Videos](#)

[Switch to SOAP Web Service version](#) [Switch to XPath version](#)

Please enter username and password to view account details

Username
 Password
[View Account Details](#)

Dont have an account? [Please register here](#)

Results for "jeremy". 40 records found.

First Name: System
 Last Name: Administrator
 Username: admin
 Password: [REDACTED]
 Signature: g0t r00t?
 Client ID: 7f2e03902758bf80b69ef9464ab0938e
 Client Secret: [REDACTED]

First Name: Adrian
 Last Name: Crenshaw
 Username: adrian
 Password: [REDACTED]
 Signature: Zombie Films Rock!
 Client ID: aaa38e73e25335aa1be03793be7303bb
 Client Secret: [REDACTED]

First Name: Patches
 Last Name: Pester
 Username: patches
 Password: [REDACTED]

Figure 2 The baseline returned 40 records. Magenta masks hide synthetic passwords and client secrets. The result count provides the visible disclosure proof.

Capture: 2026-09-29T20:55:52.224Z UTC. Baseline and final deployments use separate synthetic databases. After images show the cumulative four-fix application. Browser viewport 1280 × 960; screenshots resized proportionally for the report.

SQL injection after the fix

Assigned owner: Oshadha IT24103920

Replay the identical username and password input against the final cumulative application.

The screenshot displays the OWASP Mutillidae II web application interface. The header includes the title "OWASP Mutillidae II: Keep Calm and Pwn On", version "2.12.6", security level "0 (Hosed)", hints status "Hints: Enabled", and the logged-in user "jeremy". A navigation bar contains links: Home, Logout, Toggle Hints, Toggle Security, Enforce TLS, Reset DB, View Log, and View Captured Data. A left sidebar lists various sections: OWASP 2017, OWASP 2013, OWASP 2010, OWASP 2007, Web Services, Others, Labs, Documentation, and Resources, along with links for donating, video tutorials, announcements, and getting started. The main content area is titled "User Lookup (SQL)" and features a "Back" button, a "Help Me!" button, and a "Hints and Videos" section. Below this, there are links to switch between SOAP and XPath versions. A red error message states "Authentication Error: Bad user name or password". A form prompts the user to enter their username and password to view account details, with a "View Account Details" button. A message below the form says "Results for 'jeremy'. 0 records found." The footer shows browser and PHP version information.

OWASP Mutillidae II: Keep Calm and Pwn On
Version: 2.12.6 Security Level: 0 (Hosed) Hints: Enabled Logged In User: jeremy
Home | Logout | Toggle Hints | Toggle Security | Enforce TLS | Reset DB | View Log | View Captured Data

OWASP 2017
OWASP 2013
OWASP 2010
OWASP 2007
Web Services
Others
Labs
Documentation
Resources

Donate Today! Want to Help?
Video Tutorials
Announcements
Getting Started

User Lookup (SQL)

Back Help Me!

Hints and Videos

Switch to SOAP Web Service version Switch to XPath version

Authentication Error: Bad user name or password

Please enter username and password to view account details

Username
Password

View Account Details

Don't have an account? Please register here

Results for "jeremy". 0 records found.

Browser: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) HeadlessChrome/154.0.0.0 Safari/537.36
PHP Version: 8.2.34

Figure 3 The same input returned zero records. The browser runner separately checked valid credentials and received one record.

Capture: 2026-09-29T20:55:52.224Z UTC. Baseline and final deployments use separate synthetic databases. After images show the cumulative four-fix application. Browser viewport 1280 × 960; screenshots resized proportionally for the report.

Stored XSS before the fix

Assigned owner: Pathum IT24102334

Store the script shown below using a normal authenticated blog form, then view the stored entry.

GROUP-XSS-PROOF

OWASP Mutillidae II: Keep Calm and Pwn On

Version: 2.12.6 Security Level: 0 (Hosed) Hints: Enabled Logged In User: **jeremy**

Home | Logout | Toggle Hints | Toggle Security | Enforce TLS | Reset DB | View Log | View Captured Data

View Blogs

[Back](#) [Help Me!](#)

Hints and Videos

View Blog Entries

[+ Add To Your Blog](#)

Select Author and Click to View Blog

Please Choose Author

2 Current Blog Entries			
	Name	Date	Comment
1	jeremy	2026-09-29 20:55:54	
2	jeremy	2009-03-01 22:29:49	Mutillidae is fun

Browser: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) HeadlessChrome/154.0.0.0 Safari/537.36
PHP Version: 8.2.34

Figure 4 GROUP-XSS-PROOF appears above the application because the stored script executed. The marker is local and harmless.

```
<script>document.body.insertAdjacentHTML("afterbegin", "<h1>GROUP-XSS-PROOF</h1>")</script>
```

Capture: 2026-09-29T20:55:52.224Z UTC. Baseline and final deployments use separate synthetic databases. After images show the cumulative four-fix application. Browser viewport 1280 × 960; screenshots resized proportionally for the report.

Stored XSS after the fix

Assigned owner: Pathum IT24102334

Store and display the same payload after output encoding.

OWASP Mutillidae II: Keep Calm and Pwn On

Version: 2.12.6 Security Level: 0 (Hosed) Hints: Enabled Logged In User: **jeremy**

Home | Logout | Toggle Hints | Toggle Security | Enforce TLS | Reset DB | View Log | View Captured Data

View Blogs

[Back](#) [Help Me!](#)

Hints and Videos

View Blog Entries

[+ Add To Your Blog](#)

Select Author and Click to View Blog

Please Choose Author

2 Current Blog Entries			
	Name	Date	Comment
1	jeremy	2026-09-29 20:55:58	<script>document.body.insertAdjacentHTML("afterbegin", " GROUP-XSS-PROOF ")</script>
2	jeremy	2009-03-01 22:29:49	Mutillidae is fun

Browser: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) HeadlessChrome/154.0.0.0 Safari/537.36
PHP Version: 8.2.34

Figure 5 The script is rendered literally in the comment cell. No injected heading is present. The runner checks for a heading directly under the body.

```
<script>document.body.insertAdjacentHTML("afterbegin", "<h1>GROUP-XSS-PROOF</h1>")</script>
```

Capture: 2026-09-29T20:55:52.224Z UTC. Baseline and final deployments use separate synthetic databases. After images show the cumulative four-fix application. Browser viewport 1280 × 960; screenshots resized proportionally for the report.

Command injection before the fix

Assigned owner: Minura IT24104168

DNS input: 127.0.0.1; printf GROUP-CMD-PROOF

The screenshot shows the OWASP Mutillidae II web application interface. The header includes the title "OWASP Mutillidae II: Keep Calm and Pwn On", version "2.12.6", security level "0 (Hosed)", hints "Enabled", and a logged-in user "jeremy". A navigation bar contains links: Home, Logout, Toggle Hints, Toggle Security, Enforce TLS, Reset DB, View Log, and View Captured Data. A left sidebar lists various sections: OWASP 2017, OWASP 2013, OWASP 2010, OWASP 2007, Web Services, Others, Labs, Documentation, and Resources. Below the sidebar are links for "Donate Today! Want to Help?", "Video Tutorials", "Announcements", and "Getting Started". The main content area is titled "DNS Lookup" and features a "Back" button, a "Help Me!" button, and a "Hints and Videos" section. Below this is a "Switch to SOAP Web Service Version of this Page" link. A form labeled "Enter IP or hostname" contains a text input field with "127.0.0.1; printf GROUP-CMD-PROOF" and a "Lookup DNS" button. The results section, titled "Results for 127.0.0.1; printf GROUP-CMD-PROOF", shows "Authoritative answers can be found from:" followed by "GROUP-CMD-PROOF". The footer displays browser and PHP version information.

OWASP Mutillidae II: Keep Calm and Pwn On
Version: 2.12.6 Security Level: 0 (Hosed) Hints: Enabled Logged In User: jeremy
Home | Logout | Toggle Hints | Toggle Security | Enforce TLS | Reset DB | View Log | View Captured Data

OWASP 2017
OWASP 2013
OWASP 2010
OWASP 2007
Web Services
Others
Labs
Documentation
Resources

Donate Today!
Want to Help?

Video Tutorials

Announcements

Getting Started

DNS Lookup

Back Help Me!

Hints and Videos

Switch to SOAP Web Service Version of this Page

Enter IP or hostname

Hostname/IP

Lookup DNS

Results for 127.0.0.1; printf GROUP-CMD-PROOF

Authoritative answers can be found from:

GROUP-CMD-PROOF

Browser: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) HeadlessChrome/154.0.0.0 Safari/537.36
PHP Version: 8.2.34

Figure 6 The marker appears in the command-output box. Reflection in the results heading is not the evidence of execution.

Capture: 2026-09-29T20:55:52.224Z UTC. Baseline and final deployments use separate synthetic databases. After images show the cumulative four-fix application. Browser viewport 1280 × 960; screenshots resized proportionally for the report.

Command injection after the fix

Assigned owner: Minura IT24104168

Replay the same DNS input against GroupDns.

OWASP 2017

OWASP 2013

OWASP 2010

OWASP 2007

Web Services

Others

Labs

Documentation

Resources

Donate Today!
Want to Help?

Video Tutorials

Announcements

Getting Started

 **OWASP Mutillidae II: Keep Calm and Pwn On**

Version: 2.12.6 Security Level: 0 (Hosed) Hints: Enabled Logged In User: **jeremy**  

[Home](#) | [Logout](#) | [Toggle Hints](#) | [Toggle Security](#) | [Enforce TLS](#) | [Reset DB](#) | [View Log](#) | [View Captured Data](#)

DNS Lookup

 [Back](#)  [Help Me!](#)

 [Hints and Videos](#)

 [Switch to SOAP Web Service Version of this Page](#)

Enter IP or hostname

Hostname/IP

Results for 127.0.0.1; printf GROUP-CMD-PROOF

Invalid hostname or IP address. Request rejected.

Browser: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) HeadlessChrome/154.0.0.0 Safari/537.36

PHP Version: 8.2.34

Figure 7 The request is rejected and no execution marker appears in command output. The separate localhost positive test passed.

Capture: 2026-09-29T20:55:52.224Z UTC. Baseline and final deployments use separate synthetic databases. After images show the cumulative four-fix application. Browser viewport 1280 × 960; screenshots resized proportionally for the report.

CSRF before the fix

Assigned owner: Muditha IT24610813

Submit a unique GROUP-CSRF marker from a tokenless form at 127.0.0.1:8090 while logged into the baseline on port 8081.

GROUP-XSS-PROOF

The screenshot displays the OWASP Mutillidae II web application. The header includes the title "OWASP Mutillidae II: Keep Calm and Pwn On", version "2.12.6", security level "0 (Hosed)", hints "Enabled", and the logged-in user "jeremy". A navigation bar contains links: Home, Logout, Toggle Hints, Toggle Security, Enforce TLS, Reset DB, View Log, and View Captured Data.

The main content area is titled "Welcome To The Blog". It features a sidebar with navigation links: OWASP 2017, OWASP 2013, OWASP 2010, OWASP 2007, Web Services, Others, Labs, Documentation, and Resources. Below these are links for "Donate Today! Want to Help?", "Video Tutorials", "Announcements", and "Getting Started".

The main content area includes a "Back" button, a "Help Me!" button, and a "Hints and Videos" section. Below this is a form to "Add New Blog Entry" with a "View Blogs" link. The form contains a text input field with the value "Add blog for jeremy", a note stating ", <i> and <u> are now allowed in blog entries", and a "Save Blog Entry" button.

Below the form is a "View Blogs" link and a table titled "3 Current Blog Entries". The table has columns for Name, Date, and Comment.

	Name	Date	Comment
1	jeremy	2026-09-29 20:55:55	GROUP-CSRF-1790715352224
2	jeremy	2026-09-29 20:55:54	
3	jeremy	2009-03-01 22:29:49	Mutillidae is fun

At the bottom, there is a "CSRF Protection Information" section with a "Posted Token: (Validation not performed)" button.

Figure 8 The response was HTTP 200 and the unique entry appears in the stored blog list. This is same-site, different-origin testing with SameSite=Lax cookies.

Capture: 2026-09-29T20:55:52.224Z UTC. Baseline and final deployments use separate synthetic databases. After images show the cumulative four-fix application. Browser viewport 1280 × 960; screenshots resized proportionally for the report.

CSRF after the fix

Assigned owner: Muditha IT24610813

Replay the tokenless form against the final application on port 8080.

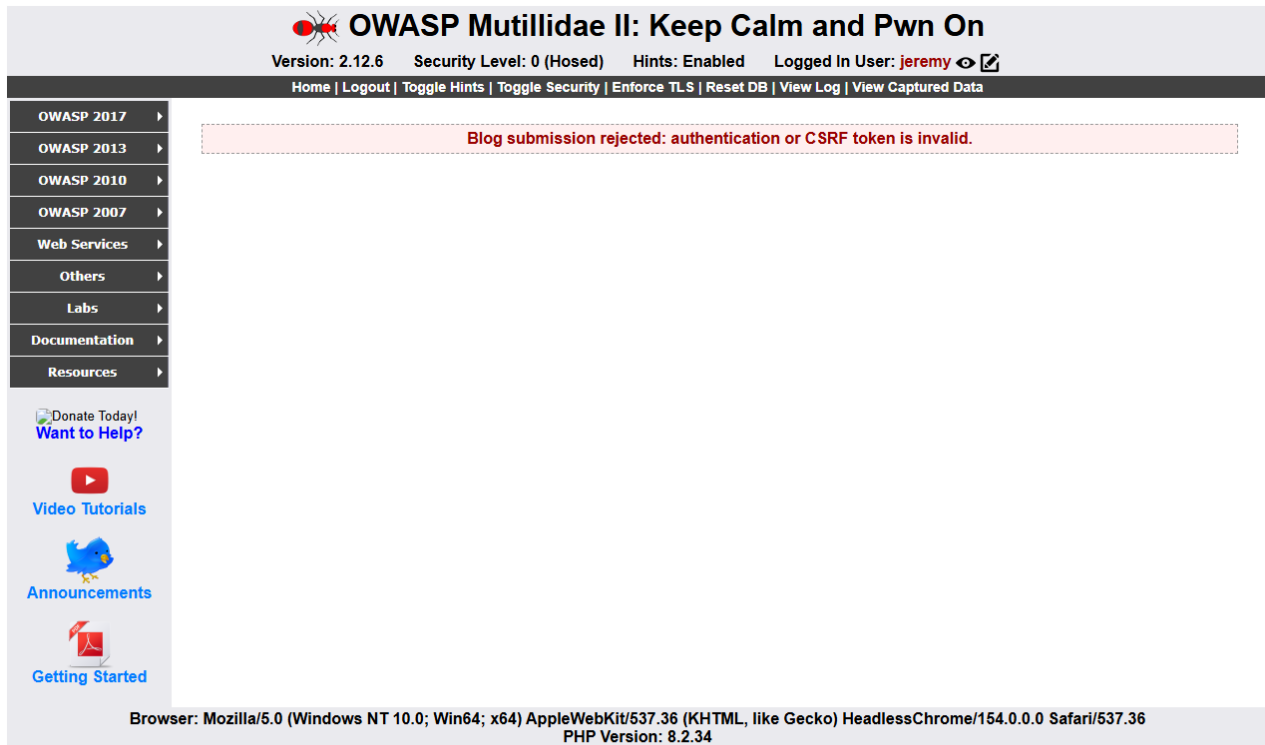


Figure 9 The response was HTTP 403. A subsequent blog read confirmed the unique entry was absent, and a valid token-bearing submission succeeded.

Capture: 2026-09-29T20:55:52.224Z UTC. Baseline and final deployments use separate synthetic databases. After images show the cumulative four-fix application. Browser viewport 1280 × 960; screenshots resized proportionally for the report.

Appendix B Verification and open findings

These are local execution results, not GitHub Actions run records. Full JSON reports accompany the submission. Vulnerability totals count package findings and can repeat an advisory across installed packages; they are not counts of unique exploitable defects.

Check	Observed result	Scope or consequence
Browser regression	15 checks passed	Real baseline and final browser runs
PHP validation	Syntax and 3 suites passed	Inherited DirectoryIterationHandler deprecation notice retained
Semgrep baseline	4 findings, exit 1	Same four targeted rules; no scanner errors
Semgrep final	0 findings, exit 0	Selected patterns only
Gitleaks directory	0 findings	Git history not yet available
Trivy dependencies	2 high, 0 critical	Exit 1; 2 package findings remain open
Trivy web image	310 high, 20 critical	Exit 1; 330 package findings remain open
Trivy MySQL image	37 high, 1 critical	Exit 1; 38 package findings remain open

The dependency report identifies two high findings for jQuery 1.8.3, NSWG-ECO-328 and NSWG-ECO-329. The inventory also records jQuery 1.3.2, Colorbox 1.3.20.2 and NuSOAP 0.9.11. Lack of reported findings for a component does not establish its safety, particularly where package mapping is incomplete.

Review image findings by package, advisory, vendor severity and available fixed version. Upgrade or replace the base image and bundled components with compatibility testing; investigate findings without a fixed version. No blanket suppression or successful hosted release is claimed.

Evidence files: http-browser-results.json, php-tests.txt, sast-before.json, sast-after.json, sast-gate-status.json, gitleaks.json, dependencies.json, web-image.json, db-image.json and image-identities.txt. Scanner databases reflect the scan date; later results may change.

Still required from GitHub: the four real PR URLs and reviewers, a failed gate demonstration run, normal pipeline results, encrypted secret configuration by name only, and a runtime workflow run. Recheck source history after all commits. The selected browser tests passed with non-loopback browser requests blocked; a full host-offline test remains to be recorded.

Appendix C Individual contributions and declarations

Complete this statement from actual work after each member reviews and tests their package. Assigned ownership below is not a record of work already performed by the students. Do not sign a claim that does not reflect your contribution.

Oshadha IT24103920

Assigned scope: SQL injection, Docker and architecture.

Actual changes and validation performed: _____

PR URL and reviewer: _____

Signature: _____ Date: _____

Pathum IT24102334

Assigned scope: Stored XSS and STRIDE threat model.

Actual changes and validation performed: _____

PR URL and reviewer: _____

Signature: _____ Date: _____

Minura IT24104168

Assigned scope: Command injection and security pipeline.

Actual changes and validation performed: _____

PR URL and reviewer: _____

Signature: _____ Date: _____

Muditha IT24610813

Assigned scope: CSRF, secrets and report integration.

Actual changes and validation performed: _____

PR URL and reviewer: _____

Signature: _____ Date: _____

AI assistance declaration: OpenAI Codex assisted with source analysis, four patches, Docker configuration, workflow files, test automation, local screenshot capture, package generation and this report. The group must verify accuracy, disclose assistance under module rules, retain upstream attribution and be able to explain the work independently. No student signatures, reviews, commit identities or GitHub evidence were generated.

Appendix D Sequential GitHub and submission workflow

1. Upload the contents of 00-foundation to main once. This contains the common application and deployment base. Keep the licence and hidden configuration files.
2. Oshadha creates member/IT24103920-sqli from main, applies package 01, reviews and tests it, commits using their own account and opens the first PR. Another member reviews it before merge.
3. Pathum pulls merged main, creates member/IT24102334-xss, applies package 02, reviews and tests, then opens the second PR. Merge after review.
4. Minura pulls merged main, creates member/IT24104168-command, applies package 03 and opens the third PR with command-injection and pipeline evidence. Read START-HERE.md for the exact branch name; package manifests are authoritative.
5. Muditha pulls merged main, creates the branch named in package 04, applies it and opens the fourth PR with CSRF, secrets and report changes. Rerun all earlier tests after merge.
6. Run and capture genuine GitHub security and runtime workflows. Do not replace failing findings with passing claims. Complete actual PR references and individual declarations in this report.
7. Make one Courseweb submission for the group. Include the PDF report, required source/repository information, evidence, contribution declarations and the actual signed Ethical Clearance Form. Check repository access and the published deadline.

The complete-project archive is the combined reference after all four patches. Uploading it before the member PRs would remove their individual diffs from review. Use each package's Apply-Package.ps1 and START-HERE.md. The helper verifies the previous stage and file hashes and never commits or pushes for a student.

Outstanding attachments: signed clearance copy; signed individual statements; real PR and Actions evidence. The user confirmed clearance submission for local Mutillidae testing, but the signed document itself was not available to include.